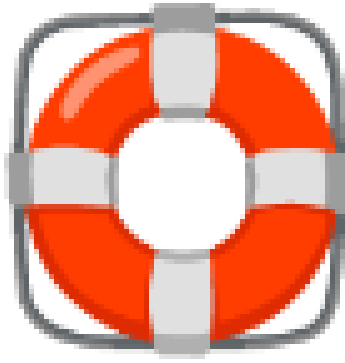


Incident Response Plan



INCIDENT RESPONSE PLAN

An **Incident Response Plan (IRP)** provides a structured approach for detecting, responding to, and recovering from cybersecurity incidents. Below is a detailed IRP tailored for a cybersecurity team associated with Capybara Unlimited, a medium-sized organization.

By integrating this detailed IRP, cybersecurity teams can ensure they are prepared to handle incidents efficiently and minimize their impact on the organization.

I. Objectives



I Objectives

I.1 Minimize Impact:

Keep damage to systems, data, and operations as low as possible by acting quickly to contain the incident, protect customer data, and keep the business running.

I.2 Restore Operations:

Get business processes and IT systems back up and running securely, focusing on critical systems and making sure everything is safe from future threats.

I.3 Enhance Security Posture:

Find and fix the vulnerabilities used in the attack, improve defenses, and make detection better for the future.

I.4 Meet Regulatory Requirements:

Stay compliant with laws, industry standards, and company policies by reporting incidents to the right people on time. Continuously improve incident response through post-incident reviews and lessons learned.



II. Scope



II Scope

Covers all IT systems, networks, applications, and people involved with Capybara Unlimited, including employees, third-party vendors, and cloud services. It also applies to customer-facing systems, making sure they stay safe and available during an incident. We prioritize protecting sensitive data, keeping services running smoothly, and following data privacy rules. Extend coverage to remote and hybrid work environments, ensuring security for employees accessing systems externally.



III. Roles & Responsibilities



III Roles & Responsibilities

The IR team consists of:

III.1 Incident Command

Leads the response process, making sure decisions align with company goals and all teams work together effectively.

III.2 SOC Analysts

Monitor systems for threats, analyze suspicious activity, and provide insights to help contain and fix the issue.

III.3 Forensic Specialists

Investigate how the attack happened, gather evidence, and support follow-up efforts to prevent it from happening again.

III.4 IT Administrators

Take care of containment, cleanup, and recovery steps to get systems back up and running safely.

III.5 Legal and Compliance Team

Ensure the response follows legal rules and industry standards, handle any required reporting, and reduce legal risks.

III.6 Public Relations/Communication Team

Manage communication with employees, customers, and the media, working with legal and leadership to provide clear and accurate updates.

III.7 All Employees or General Workforce

Report anything suspicious and follow the company's guidelines for communication to avoid confusion or misinformation.

III.8 Executive Sponsor

Provides big-picture guidance, ensures decisions align with the company's goals, and helps secure resources quickly when needed.

III.9 Threat Intelligence Team

Keeps an eye on external threats, like malware campaigns targeting the industry, to inform and strengthen the company's response.

III.10 Threat Intelligence Analysts

Collect and analyze real-time threat intelligence data, updating detection rules and supporting response decisions based on external and internal threats.

III.11 Security Awareness Team

Teaches employees about cybersecurity best practices and helps them understand how to report potential issues to protect the company.

IV. Incident Response Lifecycle



IV Incident Response Lifecycle

IV.1 Preparation

IV.1.1 Develop policies

Outline incident types, severity levels, and escalation paths.

IV.1.2 Train personnel

Conduct training sessions and practice tabletop exercises regularly.

IV.1.3 Implement tools

Ensure tools like SIEM, IDS/IPS, and backups are available and operational.

IV.1.4 Create playbooks

Develop playbooks for common incidents like phishing or malware attacks.

IV.2 Detection and Analysis

IV.2.1 Identify incidents

- **SIEM:** Use dashboards to spot unusual activity.
- **EDR:** Monitor for malware and advanced threats.
- **Network logs:** Check logs for odd traffic patterns.

IV.2.2 Classify incidents

- **Severity levels:** Low, Medium, High, Critical.
- **Type:** Malware, phishing, insider threat, DDoS, or data breach.

- **Examples:** Malware (e.g., ransomware), phishing (e.g., spear phishing emails), insider threat (e.g., data leaks), DDoS (e.g., volumetric attack), data breach (e.g., unauthorized access).

IV.2.3 Collect evidence

- *Logs, malware samples, and email headers for analysis.*

IV.2.4 Decision points

- Escalate incidents classified as High or Critical severity directly to leadership for immediate decisions.
- *Decide on containment based on the scope of the threat.*

IV.3 Containment

IV.3.1 Immediate steps

- Quarantine affected systems by disconnecting them from the network, but ensure forensic evidence is preserved.
- *Block malicious IPs or URLs with firewalls.*

IV.3.2 Short-term actions

- *Disable infected devices while preserving evidence.*
- *Redirect traffic to unaffected systems.*

IV.3.3 Long-term actions

- *Patch vulnerabilities and strengthen network segmentation.*
- Apply updates like software patches to fix vulnerabilities exploited during the attack.

IV.4 Eradication

IV.4.1 Remove malware

- *Use automated tools or manual methods to eliminate infections.*

IV.4.2 Address root cause

- *Analyze how the threat bypassed defenses.*
- *Remove persistence mechanisms like backdoors or scheduled tasks.*

IV.5 Recovery

IV.5.1 Restore operations

- *Restore systems from backups and verify their integrity.*

IV.5.2 Monitor post-incident

- *Watch for re-infection and improve detection rules.*

IV.6 Post-Incident Analysis

IV.6.1 Conduct review

- *Create a timeline of events and evaluate the response process.*
- Document key milestones, like when the incident was detected, contained, and resolved.

IV.6.2 Document findings

- *Write an incident report and summarize lessons learned.*

IV.6.3 Implement changes

- *Update IR processes and strengthen defenses.*

IV.6.4 Test updates

- Test updates to the IRP through tabletop exercises or live simulations after major incidents.

V. Communication Plan



V Communication Plan

V.1 Internal Communication

V.1.a

Notify leadership and affected departments immediately after an incident is identified.

V.1.b

Provide regular updates to leadership and affected teams throughout the incident response process to ensure alignment.

V.2 External Communication

V.2.a

Inform customers, partners, or other external stakeholders if required, ensuring timely and accurate updates.

V.2.b

Evaluate the regulatory and financial impact of incident disclosure. Always comply with mandatory reporting requirements, regardless of potential penalties. Consult legal and compliance teams to ensure accurate and timely reporting.

V.2.c

Prepare public statements with input from legal, public relations, and leadership teams to ensure transparency while protecting the company's reputation. Avoid withholding information that may lead to mistrust.

VI Key Performance Indicators (KPIs)



VI Key Performance Indicators (KPIs)

VI. Key Performance Indicators (KPIs)

1. **Time to Detect (TTD):**

This measures how long it takes to spot an incident after it starts.

- **Action:** Use detection tools like SIEM and EDR to monitor activity and aim to reduce detection time with better alerts and analysis.

2. **Time to Contain (TTC):**

This tracks how quickly the team can isolate affected systems once an incident is detected.

- **Action:** Focus on speeding up containment tasks like quarantining systems, blocking malicious IPs, or disabling compromised accounts.

3. **Time to Recover (TTR):**

This shows how long it takes to restore systems and security back to normal after an incident.

- **Action:** Log recovery activities like restoring backups, validating integrity, and re-enabling systems to identify areas for faster recovery.

4. **Incident Closure Rate:**

This is the percentage of incidents resolved within the expected timeframe.

- **Action:** Track how many incidents meet response deadlines and review any delays to improve resolution times.

5. **Post-Incident Improvement Rate:**

This measures how many lessons learned turn into real improvements in security processes or tools.

- **Action:** Identify takeaways from incident reviews and make sure they lead to updates in procedures, tools, or training.

6. **Detection Accuracy Rate (DAR):**

This tracks how often threats are correctly detected compared to false positives.

- **Action:** Review detection tools for accuracy and tune rules or thresholds to reduce unnecessary alerts while catching real threats.



VII. Common Mistakes & Mitigations



VII Common Mistakes & Mitigations

VII.1 Overlooking early indicators

VII.1.a Mistake

Dismissing minor anomalies as false positives.

VII.1.b Mitigation

Automate alert prioritization in SIEM systems and train analysts to investigate low-risk anomalies.

VII.2 Inadequate documentation

VII.2.a Mistake

Failing to log actions during incident response.

VII.2.b Mitigation

Assign a dedicated scribe during incidents and use an incident management system to centralize logs.

VII.3 Premature recovery

VII.3.a Mistake

Reconnecting systems before complete eradication.

VII.3.b Mitigation

Perform thorough validation before resuming operations, including testing for residual threats.

VII.4 Neglecting post-incident reviews

VII.4.a Mistake

Skipping post-mortem analysis due to time constraints.

VII.4.b Mitigation

Make reviews mandatory for incident closure and schedule them within a set timeframe, such as one week after the incident.

VII.5 Lack of Automation in Routine Tasks

VII.5.a Mistake

Over-reliance on manual processes during incident response.

VII.5.b Mitigation

Automate repetitive tasks like log parsing or alert prioritization using tools like Python scripts or SIEM automation.

VII.6 Overlooking Privileged Account Security

VII.6.a Mistake

Compromised privileged accounts can escalate risks during an incident.

VII.6.b Mitigation

Use privileged access management (PAM) tools and enforce multi-factor authentication (MFA) for all privileged accounts.

VII.7 Poor Communication During Incidents

VII.7.a Mistake

Delays or unclear communication between teams during incident response.

VII.7.b Mitigation

Assign clear roles in the communication plan and use collaboration tools like Slack or Microsoft Teams to enable real-time updates.

VII.8 Skipping Threat Intelligence Updates

VII.8.a Mistake

Failing to incorporate new threat intelligence into response processes.

VII.8.b Mitigation

Regularly update detection rules, mitigation techniques, and training based on the latest threat reports.

VII.9 Lack of Endpoint Visibility

VII.9.a Mistake

Incomplete monitoring of endpoints, allowing threats to go undetected.

VII.9.b Mitigation

Deploy endpoint detection and response (EDR) tools and enable comprehensive logging across all systems.

VII.10 Failing to engage external partners

VII.10.a Mistake

Not contacting ISPs or security vendors during large-scale attacks.

VII.10.b Mitigation

Establish partnerships and escalation protocols in advance for rapid engagement during incidents.

VIII. Tools & Techniques



VIII Tools & Techniques

VIII.1 Detection

- *SIEM*: Splunk, QRadar.
- *IDS/IPS*: Snort, Suricata.
- *EDR*: CrowdStrike, SentinelOne.
- *Custom Queries*: Tailor detection using SPL or regex-based patterns.
- Threat Intelligence Platforms: Recorded Future, AlienVault.

VIII.2 Containment

- *NAC*: Cisco ISE.
- *Firewalls*: Palo Alto, Fortinet.

VIII.3 Eradication

- *Antivirus/Antimalware*: Sophos, Malwarebytes, Windows Defender.
- *Scripting*: Ansible or Terraform for automating fixes or updates.

VIII.4 Recovery

- *Backup Solutions*: Veeam, Acronis.
- *Version Control*: Use Git to restore or manage configuration changes.

VIII.5 Analysis

- *Forensic Tools*: FTK, EnCase, Wireshark.
- *Programming Tools*: Python, PowerShell, Bash for scripting and automation.

- *Threat Hunting*: Jupyter Notebooks for data analysis and visualization.
- Data Visualization Tools: Tableau, Kibana.



IX. Review & Maintenance



IX Review and Maintenance

IX.1 Regular Updates

Review and update the IRP annually or whenever necessary due to compliance needs, lessons learned from incidents, or changes in the threat landscape.

IX.2 Ongoing Training

Conduct quarterly training sessions and simulations to keep the team prepared and up to date on new threats and tools.

IX.3 Audits

*Perform regular audits using internal experts for routine evaluations and third-party auditors to ensure unbiased assessments and uncover potential blind spots. *Engage third-party penetration testers annually to identify and address security weaknesses.*

IX.4 Lessons Learned Integration

Incorporate lessons learned from incidents into the IRP to address gaps and improve response strategies.

IX.5 Threat Landscape Monitoring

Continuously monitor the threat landscape and update the IRP to address new and emerging risks.

IX.6 Stakeholder Feedback

Gather feedback from the incident response team and leadership to refine training, simulations, and IRP processes.

Appendix



APPENDIX



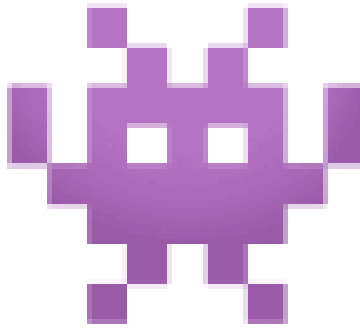


Playbooks



IR PLAYBOOKS

Malware Infection



Malware Infection Playbook

1. Identify and Contain the Malware

Quickly detect and limit the spread of the malware to minimize damage.

1.1 Identify and isolate infected systems

Immediately isolate infected systems from the network to prevent further spread while preserving forensic data.

1.2 Conduct preliminary analysis

Gather initial indicators of compromise (e.g., suspicious files, processes, or connections) to inform containment strategies.

1.3 Leverage threat intelligence feeds

Compare preliminary indicators (e.g., file hashes, IPs) against threat intelligence feeds to identify known malware and associated TTPs.

2. Perform Static Analysis of the Malware Sample

Analyze the malware file without executing it to understand its characteristics.

2.1 Inspect file structure and metadata

Examine the malware file's properties, including size, hash values, and embedded metadata.

2.2 Extract embedded strings and suspicious code

Use tools like VirusTotal to identify readable text and suspicious code within the file.

3. Perform Dynamic Analysis in a Controlled Environment

Observe malware behavior in real-time to understand its operational capabilities.

3.1 Execute malware in a sandbox environment

Run the malware in a secure, isolated sandbox to observe its behavior and collect forensic artifacts.

3.2 Record system modifications and activities

Document changes to the registry, file systems, and active processes during execution.

4. Conduct Network Traffic Analysis

Analyze communication attempts made by the malware to uncover external connections.

4.1 Capture network traffic

Use packet-capturing tools to monitor network activity generated by the malware.

4.2 Identify external entities

Look for connections to command-and-control (C2) servers or data exfiltration endpoints.

5. Investigate Behavioral Patterns and Persistence Mechanisms

Determine how the malware survives and operates over time.

5.1 Identify persistence techniques

Investigate changes such as registry modifications, scheduled tasks, startup files, hidden services, and DLL hijacking.

5.2 Examine behavioral indicators

Look for recurring patterns, such as periodic network requests or file executions.

6. Eradicate the Malware and Recover Systems

Remove the malware and restore affected systems to their original state.

6.1 Deploy cleanup tools

Use antivirus or specialized malware removal tools to eradicate infections.

6.2 Restore from clean backups

Reinstall systems and data using backups confirmed to be malware-free.

6.3 Apply mitigations to prevent reinfection

Address vulnerabilities that allowed the infection by applying appropriate mitigations.

6.4 Validate system integrity

Perform post-recovery validation to confirm no residual malware or vulnerabilities remain in the environment.

7. Post-Incident Reporting and Prevention

Document lessons learned and strengthen defenses against future incidents.

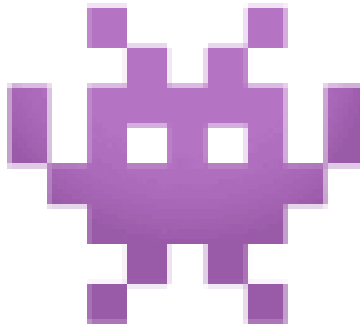
7.1 Generate incident report

Detail findings, response steps, and impact assessment in a comprehensive report.

7.2 Implement prevention measures

Update security policies, patch vulnerabilities, and educate staff to avoid recurrence.

Phishing



Phishing Playbook

1. Identify and verify the phishing email

Confirm that the suspicious email is a phishing attempt, not a legitimate message.

1.1 Analyze email headers and content

Check email headers for things that don't add up, like mismatched sender addresses or unusual reply-to addresses. Look for signs in the content like generic greetings, spelling errors, or requests for sensitive info that seem urgent.

1.2 Compare against known phishing indicators

Hover over links to see if they match what they claim to be. Check for fake branding, suspicious attachments, or other common phishing signs.

1.3 Issue early warnings to employees

Send an immediate alert to all employees about the phishing email to reduce the chance of further interactions.

2. Contain the threat

Prevent further exposure or escalation.

2.1 Isolate the email

Tell recipients not to open attachments, click on links, or reply. Move the email to a quarantine or flag it as phishing so it can't cause further issues.

2.2 Notify IT/security team

Let the security team know right away by following your organization's reporting process.

3. Investigate the impact

Determine the extent of the threat and affected users.

3.1 Verify user interaction

Actively confirm with users if they interacted with the email. Use monitoring tools to detect compromised systems or unauthorized downloads.

3.2 Check affected systems

Use tools like EDR to check devices for malware or strange behavior that might have come from interacting with the phishing email.

3.3 Retrieve user details if interactions occurred

Ask employees who interacted with the email to provide details like screenshots, links they clicked, or information they entered.

4. Eradicate the threat

Remove malicious elements and secure compromised accounts or systems.

4.1 Preserve phishing emails

Save the email in a secure folder so the security team can study it without risking accidental clicks or replies.

4.2 Secure compromised accounts

If someone entered their credentials, reset their passwords right away and watch for any suspicious account activity.

4.3 Notify external service providers if applicable

If the phishing attempt targeted external accounts (e.g., banking credentials), notify the affected service providers to add extra protections.

5. Educate and prevent future incidents

Strengthen user awareness and defenses.

5.1 Notify all employees

Let employees know about the phishing email with actionable advice on how to handle similar threats in the future.

5.2 Provide training

Run phishing awareness workshops and send out fake phishing emails to help employees recognize and handle them better.

5.3 Review email security policies

After training sessions, review existing security policies to ensure they reflect best practices and address any gaps.

6. Monitor and report

Ensure no residual threats remain and document the incident.

6.1 Monitor for recurrence

Keep an eye on systems and accounts to make sure the phishing attempt doesn't cause more problems later.

6.2 Document the incident

Write down what happened, what actions were taken, and what was learned so the response process can improve next time.

6.3 Report to external agencies if required

For incidents involving sensitive customer data or widespread impact, report the details to regulatory bodies or threat intelligence platforms.

Denial-of-Service



Denial-of-Service Playbook

1. Identify and characterize the attack traffic

Confirm the nature of the traffic to ensure it's consistent with a DoS attack rather than a legitimate traffic spike.

1.1 Automate detection of unusual number of packets

Use network tools to spot weird patterns, like a ton of requests from the same IPs or specific kinds of packets flooding the network.

1.2 Classify the type of DoS

Figure out the kind of attack, like SYN floods or ICMP floods, by comparing it to known attack types.

1.3 Set up automated alerts for unusual patterns

Configure network monitoring tools to trigger alerts when unusual traffic spikes or patterns are detected.

2. Measure traffic volume and bandwidth consumption

Accurately assess traffic volume to prioritize resources and decide on appropriate mitigation strategies.

2.1 Assess scope of DoS

Check how big the attack is by looking at the size of packets, the rate of requests, and how much it's using up your network.

2.2 Evaluate impact of DoS

Use what you've measured to see how badly the attack is affecting performance and where it's hitting hardest.

3. Locate the source of attack traffic

Identify potential malicious sources to inform targeted blocking or rate-limiting actions.

3.1 Identify patterns in DoS traffic source

Look for patterns in where the traffic is coming from, like specific IP ranges, locations, or botnet signs.

3.2 Analyze identified patterns

Write down any repeat offenders, like suspicious IPs or regions, so you know where the attack might be coming from.

4. Identify affected services and network components

Pinpoint affected systems to prioritize protective measures and service continuity efforts.

4.1 Identify affected internal systems

Figure out which of your systems—like web servers or DNS—are getting hit the hardest using logs and network monitoring.

4.2 Prioritize critical services

Make sure your most important systems, like public-facing servers, stay up and running by focusing resources there first.

4.3 Notify stakeholders

Keep leadership, affected teams, and external partners updated about impacted services and progress.

5. Implement and monitor mitigation measures

Ensure mitigation is effectively reducing malicious traffic while maintaining service availability for legitimate users.

5.1 Implement firewall rules

Set up rules in your firewalls or limit traffic rates to block the attack and protect your network.

5.2 Monitor effectiveness of firewall mitigations

Keep an eye on your defenses to make sure they're actually stopping the attack and not blocking good traffic.

5.3 Enable threat intelligence integrations

Use updated threat lists to block bad IPs or attackers as soon as they're detected.

5.4 Backup configurations before changes

Save current network and firewall configurations before applying new rules or rate limits to allow quick rollback if needed.

6. Post-Mitigation Monitoring and Reporting

Document lessons learned and ensure no residual impact remains.

6.1 Monitor for residual impact

Keep watching for leftover signs of the attack or anything that might flare back up.

6.2 Document incident findings

Write up what happened, what worked, and how things can be handled better next time.

6.3 Conduct post-incident DDoS simulations

Use simulations to test defenses, identify gaps, and ensure response playbook is effective.